

CSIRT / Incident Response Security Lab

CSIRT・インシデントレスポンスを実践的に学習するための ホームセキュリティラボです。

VMware Workstation上に Kali Linux、Ubuntu Server、Windows 11 を構築し、隔離した仮想ネットワーク内で実験を行っています。

目的

セキュリティツールの使い方を覚えるだけではなく、

「ある操作を行うと、ネットワークやサーバーでは何が起きるのか」

「その痕跡を防御側からどのように発見・調査できるのか」

を実際のパケットやログから理解することを目的としています。

最終的には、

Detection ↓ Triage ↓ Investigation ↓ Containment ↓ Recovery ↓ Lessons Learned

まで、一連のインシデントレスポンスを自分のラボ内で再現することを目指します。

Lab Environment

Machine	Role	CPU	RAM	Storage
Kali Linux	攻撃・診断・調査	TBD	TBD	TBD
Ubuntu Server	Linux Server / 調査対象	2 vCPU	6 GB	40 GB
Windows 11	Client / 調査対象	TBD	TBD	TBD

Virtualization: VMware Workstation

Network

実験時はVMware Host-only Networkを使用します。

```
Kali Linux          Ubuntu Server
192.168.159.131      192.168.159.129
  |                   |
+----- Host-only -----+
      192.168.159.0/24
      |
    Windows 11
```

VM同士は通信できますが、検証時は外部ネットワークから分離します。

パッケージのインストールなど、インターネット接続が必要な場合のみ NATを使用します。

Learning Cycle

このラボでは、

目的↓仮説↓実験↓観測↓結果↓考察↓次の仮説

というサイクルで検証を進めます。

このラボで行うこと

このラボでは、攻撃手法そのものを試すことだけを目的にはしません。

隔離された環境内で意図的に通信やイベントを発生させ、

1. どのような通信が発生したのか
2. 対象端末にはどのようなログが残ったのか
3. Blue Team側から検知できるのか
4. 何が起きたのかログから再現できるのか
5. 影響範囲をどのように判断するのか
6. どのように封じ込め・復旧するのか

までを一つの演習として扱います。

Lab Roles

3台の仮想マシンには、それぞれ役割を持たせています。

Kali Linux

攻撃・診断・検証用端末。

主な用途:

- Nmapによるネットワーク調査
- ポートスキャン
- サービス調査
- 通信の生成
- Blue Team検知ルールのテスト
- インシデント再現用の検証端末

Kaliで発生させた通信を「正解」として、UbuntuやWindows側にどのような痕跡が残るか確認します。

Ubuntu Server

Linuxサーバー兼、Blue Teamの調査対象。

主な用途:

- SSH Server
- tcpdumpによるパケット取得
- TSharkによる通信解析
- journalctlによるログ調査

- auditdによる監査
- プロセス調査
- ネットワーク接続調査
- 不審なアクセスの検知

現在:

```
IP           : 192.168.159.129/24
Interface    : ens33
CPU          : 2 vCPU
RAM          : 6 GB
Storage      : 40 GB
```

Windows 11

一般的なユーザー端末を想定した調査対象。

今後、

- Windows Event Log
- Sysmon
- PowerShell Logging
- Process Creation
- Network Connection
- Logon Event
- ファイル作成・変更

などを記録し、Windows端末で発生したイベントを Blue Team側から追跡できる環境にします。

Exercise Roadmap

STEP 1 - ネットワーク基礎

まず、ラボ内で何が通信しているのかを理解します。

行うこと:

- IPアドレス確認
- サブネット確認
- ルーティング確認
- Default Gateway確認
- NATとHost-onlyの比較
- ARP確認
- ICMP確認
- DNS確認
- TCP通信確認

使用する主なコマンド:

```
ip addr
ip route
ip neigh
ping
ss
tcpdump
```

目標:

「どの端末から、どの端末へ、どの経路で通信しているのか」

を説明できるようにする。

STEP 2 - Nmap / TCP解析

KaliからUbuntuへポートスキャンを行います。

Kali:

```
sudo nmap -sS 192.168.159.129
```

Ubuntu:

```
sudo tcpdump -i ens33 -nn 'tcp'
```

確認する内容:

- SYN
- SYN-ACK
- ACK
- RST
- OPEN
- CLOSED
- TCP 3-way handshake
- SYN Scan

目標:

Nmapに

```
22/tcp open
```

と表示された結果だけを見るのではなく、

「なぜNmapがOPENだと判断できたのか」

をパケットから説明できるようにする。

STEP 3 - Blue Team Exercise 01

ポートスキャンを検知する

ここからBlue Team側の演習を開始します。

目的

攻撃元を知らないという前提で、取得した通信からポートスキャンを発見する。

仮説

同一IPアドレスから短時間に多数のTCPポートへSYNが送られた場合、

```
Port Scan
```

の可能性があると判断できる。

イベント発生

KaliからUbuntuへスキャンを実施する。

```
Kali
192.168.159.131
    |
    | SYN
    | SYN
    | SYN
    | SYN
    v
Ubuntu
192.168.159.129
```

Blue Team

Ubuntu側で通信を取得する。

```
sudo tcpdump -i ens33 -nn 'tcp'
```

調査時には、

- Source IP

- Destination IP
- Destination Port
- TCP Flags
- Timestamp
- 接続回数

を確認する。

調査

例えば、

```
192.168.159.131 -> port 22
192.168.159.131 -> port 80
192.168.159.131 -> port 443
192.168.159.131 -> port 445
192.168.159.131 -> port 3306
...
```

のような通信が短時間に集中していれば、

「192.168.159.131からポートスキャンが行われた可能性」

を調査する。

ゴール

Kaliを見なくても、

```
発生時刻
↓
Source IP
↓
Destination IP
↓
Destination Port
↓
TCP Flags
```

からスキャン元を特定できるようにする。

STEP 4 - Blue Team Exercise 02

SSHイベントを調査する

次はネットワークだけではなく、OS側のログを調査します。

確認するもの:

```
journalctl  
  
/var/log/auth.log  
  
auditd
```

など。

ネットワークでは、

```
Kali  
|  
| TCP/22  
v  
Ubuntu
```

しか分からなかった通信を、

誰が接続したのか

認証は成功したのか

いつログインしたのか

ログイン後に何が起きたのか

というホスト側の情報と組み合わせて調査します。

STEP 5 - Linux Investigation

Ubuntu Serverでインシデントが発生したという想定で、端末を調査します。

確認対象:

- ログイン履歴
- 実行中プロセス
- ネットワーク接続
- Listening Port
- ユーザー
- ファイル
- サービス
- systemd
- cron

- SSH
- audit log

目的は、

「現在何が動いているのか」

だけではなく、

「過去に何が起きたのか」

をログから復元することです。

STEP 6 - Windows Blue Team

Windows 11にSysmonを導入し、Windows側のテレメトリを増やします。

確認予定:

- Process Creation
- Network Connection
- Logon
- PowerShell
- File Creation
- Service
- Scheduled Task
- Windows Defender
- Windows Event Log

最終的には、

```
Network Log
  +
Linux Log
  +
Windows Event Log
  +
Sysmon
```

を組み合わせて調査します。

STEP 7 - Timeline Analysis

複数のログを時系列に並べます。

例えば、

```
10:00:01
Port Scan

    ↓

10:01:32
SSH Connection

    ↓

10:02:04
Authentication

    ↓

10:02:10
Process Start

    ↓

10:03:15
Network Connection
```

のように、

「何が、どの順番で起きたのか」

をTimelineとして復元します。

STEP 8 - Detection

人間がログを読めば分かる状態から、自動的に異常を見つけられる状態へ進めます。

検討する検知:

- Port Scan Detection
- SSH Authentication Failure
- Suspicious Login
- Suspicious Process
- Unexpected Network Connection
- IOC Detection

ここでは、

何を異常とするのか

どのログが必要なのか

誤検知は発生しないか

も考えます。

STEP 9 - Incident Response Exercise

最終的には、最初から答えを見ない演習を行います。

Blue Teamには、

「Ubuntu Serverで不審な通信を検知した」

など最低限の情報だけを与えます。

そこから、

```
Detection
|
v
Triage
|
v
Investigation
|
v
Scope Identification
|
v
Containment
|
v
Eradication
|
v
Recovery
|
v
Lessons Learned
```

まで実施します。

Investigation Questions

各演習では、最低限以下の質問に答えます。

What?

何が起きたのか

When?

いつ起きたのか

Where?

どの端末で起きたのか

Who?

どのユーザー / IPが関係しているのか

How?

どのように発生したのか

Impact?

どこまで影響したのか

Evidence?

その判断の根拠は何か

Learning Cycle

各演習は以下のサイクルで記録します。

目的

↓

仮説

↓

イベント発生

↓

観測

↓

Blue Team調査

↓

結果

↓

考察

↓

検知方法を考える

↓

次の仮説

Current Progress

- ☒ VMware Workstation環境構築

- ☒ Kali Linux構築
- ☒ Ubuntu Server構築
- ☒ Windows 11構築
- ☒ Host-only Network構築
- ☒ Kali ↔ Ubuntu疎通確認
- ☒ Nmap導入
- ☒ tcpdump導入
- ☒ Nmap SYN Scan
- ☒ SYN / SYN-ACK / RST観測
- ☐ Port Scan Detection
- ☐ SSH Log Investigation
- ☐ Linux Incident Investigation
- ☐ Windows Sysmon
- ☐ Windows Event Log Analysis
- ☐ Timeline Analysis
- ☐ Detection Rule
- ☐ Incident Response Exercise

Lab Notes

実際に行った作業や、途中で分からなかったこと、実験結果、考察については [logs/](#) に残します。

- 2026-09-22 - ラボ構築 / Nmap / tcpdump / TCP SYN Scan

READMEにはプロジェクト全体の構成と目標を書き、日々の試行錯誤はLab Notesとして残していきます。